

Secure Coding Checklist

A one-page reference to keep next to your review queue. Nothing here is exotic; the point is that these are the things that actually come up.

Every input crossing a trust boundary

- Where did this come from? User, service, queue, file on disk.
- What am I about to do with it? Query, template, shell, path.
- What is the worst thing it could be? Not what you expect - what is possible.

Injection

- Parameterised queries with bound values, never string concatenation.
- Dynamic identifiers such as sort columns validated against an allowlist.
- Encoding applied at the point of use, in the target context.
- No raw SQL escape hatches without a review comment explaining why.

Authentication and sessions

- Passwords hashed with a slow algorithm and a per-user salt.
- Identical error for unknown account and wrong password.
- Session cookies httpOnly, secure, and sameSite.
- Authorisation checked on the server for every request, not just in the UI.

Secrets and dependencies

- No secrets in source, fixtures, or committed env files.
- Lockfile committed; dependency bumps reviewed like code.
- Extra scrutiny for packages touching auth, crypto, or serialisation.
- Watch for install scripts - they run before your tests do.

Before you approve

- Could this log something sensitive?
- Does the error message leak internals to the caller?
- Is there a test that fails if the check is removed?